Security Review

Cantina Managed

SKY: LZ DEPLOYER

Cantina Managed review by:
Christoph Michel, Lead Security Researcher
M4rio.eth, Lead Security Researcher

CANTINA

October 24, 2026

Contents

1 Introduction **2**
- 1.1 About Cantina . . . 2
- 1.2 Disclaimer . . . 2
- 1.3 Risk assessment . . . 2
  - 1.3.1 Severity Classification . . . 2

2 Security Review Summary **3**
- 2.1 Scope . . . 3

3 Findings **4**
- 3.1 Informational . . . 4
  - 3.1.1 Minor issues, Typos & Documentation . . . 4

1 Introduction

1.1 About Cantina

Cantina is a security platform that pairs a world-class network of security researchers with agentic AI to help teams building onchain find and fix real risk. Through managed reviews, competitions, and bounties, Cantina secures protocols before vulnerabilities can be exploited.
Learn more at cantina.security

1.2 Disclaimer

Cantina Managed provides a detailed evaluation of the security posture of the code at a particular moment based on the information available at the time of the review. While Cantina Managed endeavors to identify and disclose all potential security issues, it cannot guarantee that every vulnerability will be detected or that the code will be entirely secure against all possible attacks. The assessment is conducted based on the specific commit and version of the code provided. Any subsequent modifications to the code may introduce new vulnerabilities that were absent during the initial review. Therefore, any changes made to the code require a new security review to ensure that the code remains secure. Please be advised that the Cantina Managed security review is not a replacement for continuous security measures such as penetration testing, vulnerability scanning, and regular code reviews.

1.3 Risk assessment

Severity level	Impact: High	Impact: Medium	Impact: Low
Likelihood: high	Critical	High	Medium
Likelihood: medium	High	Medium	Low
Likelihood: low	Medium	Low	Low

1.3.1 Severity Classification

The severity of security issues found during the security review is categorized based on the above table. Critical findings have a high likelihood of being exploited and must be addressed immediately. High findings are almost certain to occur, easy to perform, or not easy but highly incentivized thus must be fixed as soon as possible.

Medium findings are conditionally possible or incentivized but are still relatively likely to occur and should be addressed. Low findings are a rare combination of circumstances to exploit, or offer little to no incentive to exploit but are recommended to be addressed.

Lastly, some findings might represent objective improvements that should be addressed but do not impact the project's overall security (Gas and Informational findings).

2 Security Review Summary

From Oct 9th to Oct 13th the Cantina team conducted a review of lz-deploy on commit hash b295d5c9. The team identified **1** issue:

Issues Found

Severity	Count	Fixed	Acknowledged
Critical Risk	0	0	0
High Risk	0	0	0
Medium Risk	0	0	0
Low Risk	0	0	0
Gas Optimizations	0	0	0
Informational	1	1	0
Total	**1**	**1**	**0**

2.1 Scope

The security review had the following components in scope for lz-deploy on commit hash b295d5c9:

```
src/L1OFTDeployer.sol
src/L1SsrBridgeDeployer.sol
src/L2GovBridgeDeployer.sol
src/L2OFTDeployer.sol
src/L2SsrBridgeDeployer.sol
```

3 Findings

3.1 Informational

3.1.1 Minor issues, Typos & Documentation

Severity: Informational.

Context: (see each case below).

Description:

1. README.md#L68: The documentation does not clearly distinguish which OFT deployment and activation steps (`wireGovPeer` , `wireOftPeer` and `activateOft` calls) occur on L1 vs L2 when adding a new chain, and with what rate limits. A clearer description for the step 5 L1 spell could be:

```
5. **The L1 spell**
   - Call `LZDVNInit.wireCCIPDVN` for the new chain's route on the shared CCIP DVN
   ↪  adapter.
   - Call `wireGovPeer` for the governance path.
   - Call `wireOftPeer` with the intended rate limits on each existing L1 OFT to add
   ↪  the newly deployed L2 OFT as a remote.
   - Call `relayToL2` with `LZL2Spell.activateOft` with the intended rate limits for
   ↪  each newly deployed L2 OFT configured with zero initial limits. Skip this step
   ↪  for L2 OFTs already preconfigured with non-zero limits.
```

Recommendation: Consider addressing the mentioned issues.

Sky: Fixed in commit e0b2b169.

Cantina Managed: Fix verified.